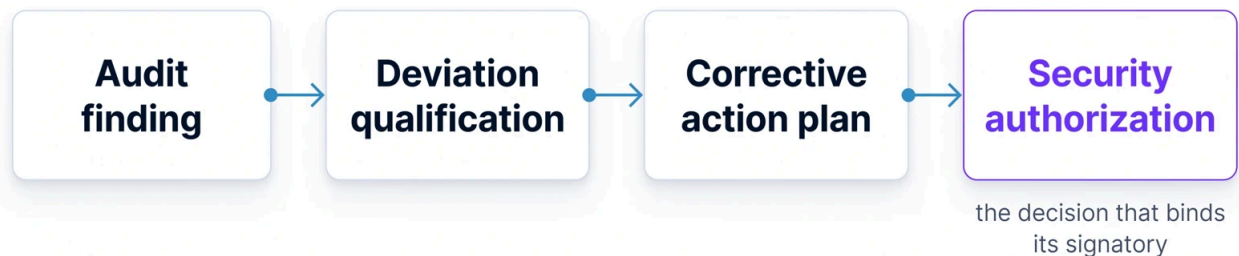


Grading deviations and the security authorization process

✓ From the raw finding to the decision that commits



Session objectives

By the end of this tutorial:

- **Grade** an audit finding: compliant, major nonconformity, minor nonconformity or observation, with a justification that holds up in front of the auditee
- **Distinguish** the correction, which makes the deviation disappear, from the corrective action, which makes its cause disappear, and build a usable corrective action plan

- **Describe** the French-style security authorization process (« homologation »): its four-step approach, its three levels, its authority and its decision

Prerequisites

- This morning's lecture: the chain criterion, evidence, finding, deviation, nonconformity, observation. It serves on every line of this tutorial.
- The group's audit criteria: the ISO/IEC 27001:2022 framework chosen in session 3, and the framework PSSI directives as codified in session 1 (ACC-01 to COR-01).
- The regulatory context of the subsidiary under review, seen in session 3, and the question Executive Management asks about it at the end of the subsidiary pack (section 7); for Territoires, the RGS governs the exchanges of its client local authorities, and its first obligation is to conduct a security authorization.

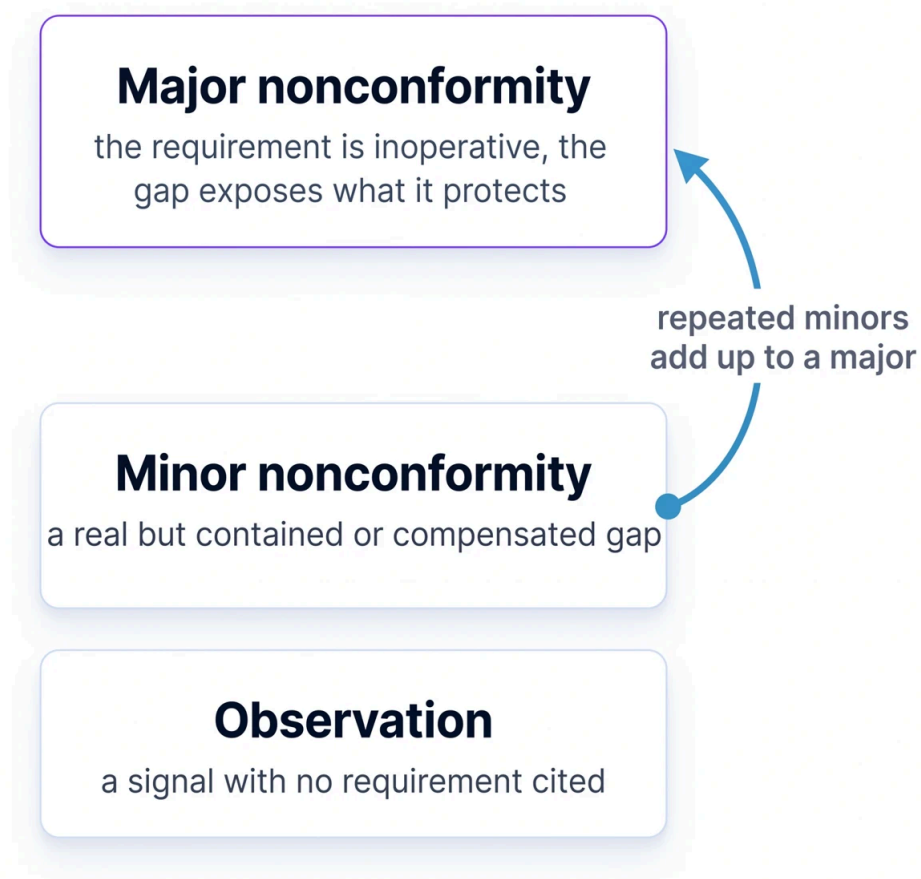
✓ Presentation: grade, correct, authorize

Ten minutes of new material before getting to work, in two parts.

The grading of deviations, and why it exists

This morning's lecture stopped at the moment the deviation is established: a **compliance deviation**, that is, an observed situation that does not satisfy the audit criterion. Yet not all deviations carry the same weight, and a report presenting them flat would be both unfair and unusable: management must know where the ground is burning. That is the role of **deviation grading**, and the ANSSI and DINUM security authorization guide states its principle in one sentence: « Les audits peuvent identifier des non-conformités mineures et majeures. » (audits can identify minor and major nonconformities.)

The precise definitions vary between frameworks and bodies; those that follow are the module's working definitions, and they are enough to settle almost every case. A **major nonconformity** is a deviation that compromises the capacity of the arrangement to reach its security objective: the requirement is absent or inoperative over the scope, or the deviation immediately exposes what the requirement protects. A **minor nonconformity** is a real but circumscribed deviation: the requirement exists and works for the most part, the failure is one-off, isolated, or compensated by another control. The accumulation rule, a classic among certifiers, deserves to be known: several minors repeated on the same requirement sketch a major, because the repetition proves that the arrangement does not correct itself. The "**observation**", finally, has been known since this morning: a signal the auditor cannot hook to a precise requirement of the criterion, and which is recorded because keeping quiet about it would be dishonest; some French reports also call it a point of attention or an avenue for progress. The boundary to defend at the presentation: a grading is justified by the cited requirement and by the measured extent of the deviation, never by felt severity. The weight in risk, severity and likelihood, will be the work of session 5; today the grading is done against the criterion.



It remains to say what is done with a nonconformity, and the vocabulary of ISO/IEC 27000:2018 distinguishes two gestures everyone confuses. The **correction** means “action to eliminate a detected nonconformity”: making the established deviation disappear; the shared account is revoked, the missing MFA is deployed. The “**corrective action**” means “action to eliminate the cause of a nonconformity and to prevent recurrence”: making the cause disappear so the deviation cannot come back; one asks WHY the account was shared, and repairs the process that allowed it. A **corrective action plan** worthy of the name carries both, and the security authorization guide gives it its method: actions that are specific, measurable, achievable and realistic, defined in time, the SMART method, gathered into a single plan which is, in the guide’s words, « la pierre angulaire de l’amélioration continue » (the cornerstone of continuous improvement). Correcting without treating the cause is mopping up under a leak.

Correction

removes the observed deviation

revoke the shared account

Corrective action

removes the cause of the deviation

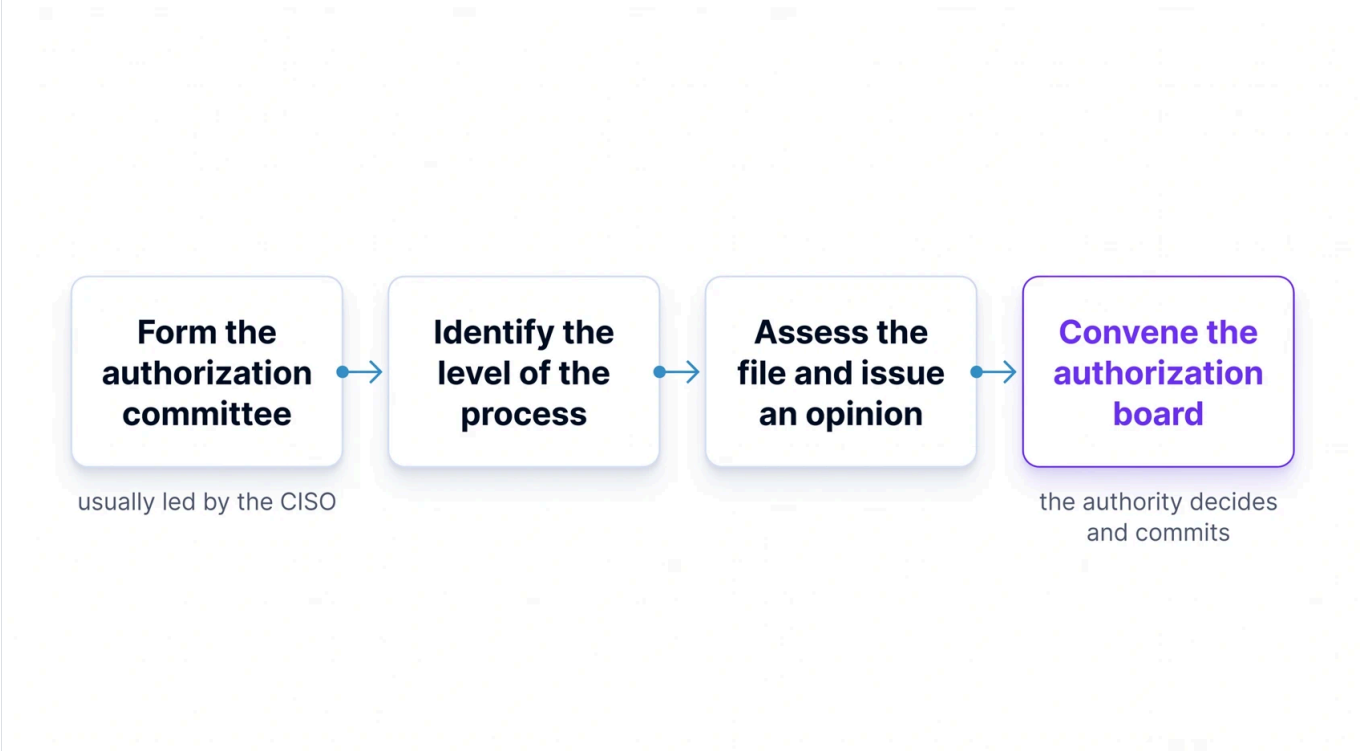
fix the process that allowed it

Security authorization: the decision that owns the remaining risks

Second part, and this is a very French, very structured object that every professional in France ends up meeting. The problem it solves: an audit produces findings, an action plan produces promises, but nobody, at this stage, has DECIDED to operate the system in full knowledge of the facts. Who accepts the residual risks? Who commits their responsibility if one of them materializes? The **“security authorization”** is that decision, called « homologation » in French practice. The glossary of the EBIOS RM method (expression des besoins et identification des objectifs de sécurité, Risk Manager) defines it thus: « Validation par une autorité dite d'homologation, que le niveau de sécurité atteint par l'organisation est conforme aux attentes et que les risques résiduels sont acceptés dans le cadre de l'étude. » (validation, by a so-called authorizing authority, that the level of security reached by the organization meets expectations and that the residual risks are accepted within the frame of the study.) And the security authorization guide, published by ANSSI with DINUM, sets its nature: « Une homologation de sécurité est un acte formel qui engage l'autorité qui la prononce. » (a security authorization is a formal act that commits the authority that pronounces it.) The nuance that throws everyone, to remember: « Un système d'information peut être homologué même s'il comporte des risques non traités mais acceptables par l'autorité. » (an information system can be authorized even if it carries risks that are untreated but acceptable to the authority.) To pronounce the authorization is not to certify that all is well; it is to accept, in writing, in one's own name, what is not yet well.

The **authorization process**, in the guide's current doctrine, is a four-step approach: form the authorization committee, generally led by the CISO, which gathers business lines, designers, operators, auditors; identify the level of the approach; evaluate the exhibits of the authorization file and issue an opinion; organize the authorization board, where the authority decides. Three levels of approach exist, proportionate to the stakes:

simplified, for a system of little or no criticality; intermediate, for a somewhat more critical or exposed system, for example one processing personal data; reinforced, for systems handling sensitive information or of critical importance. The level is chosen by crossing the system's criticality with its exposure to risk sources, and the guide warns against the technician's reflex: « La sélection du niveau de la démarche d'homologation ne doit pas dépendre de la complexité du système d'information, mais de sa criticité, de son exposition aux sources de risques numériques et au niveau de la menace. » (the selection of the level of the authorization approach must depend not on the complexity of the information system, but on its criticality, its exposure to digital risk sources and the level of the threat.)



	Zero exposure	Low exposure	Significant exposure	Total exposure
Maximum criticality	Intermediate	Reinforced	Reinforced	Reinforced
Significant criticality	Intermediate	Intermediate	Reinforced	Reinforced
Moderate criticality	Simplified	Simplified	Intermediate	Intermediate
Minor criticality	Simplified	Simplified	Simplified	Intermediate

Three markers complete the table. The authorizing authority is never the auditor nor the committee leader: it is an officer who can commit the organization, an executive or their delegate, and the guide wants this authority « au plus proche du métier du système d'information » (as close as possible to the business served by the information system). The committee's opinion can be unfavourable, and the guide makes a virtue of it: « Ne pas donner d'avis positif sur la sécurité d'un système d'information est un signal fort. » (not giving a positive opinion on the security of an information system is a strong signal.) It can also be favourable subject to reservations, operation then being

authorized on condition that the actions lifting the reservations are carried out within twelve months at most. And the decision is never eternal: the guide recommends not pronouncing an authorization of more than three years, without automatic renewal, with a security review at least yearly. Finally, the three words of the term, never to be confused again:

	Who pronounces	Against what	What it produces
Certification	An accredited third-party body	A requirements standard (ISO/IEC 27001)	A certificate, proof defensible before the market, over a scope
Security authorization	An accountable internal authority	The system's security expectations and residual risks	A formal decision to operate, which commits its signatory
Regulatory compliance	A regulator, where applicable	The law and its frameworks	An obligation met, or a sanction

The risk analysis, which the authorization file requires for the demanding approaches, arrives in session 5: today, this tutorial teaches how to prepare everything else.

✓

Exercise 1: grade the findings of the audit programme (15 minutes)

The group's first internal audit cycle, launched this morning, reports the following findings, taken from the four subsidiaries. They are correctly worded, evidence and criterion in support; they are not yet graded, and they are graded on what the table states, the reference pack (section 4) giving the context of each. The criteria in force: the ISO/IEC 27001:2022 framework (Annex A) and the group's framework PSSI directives. The framework policy directives as codified in session 1 (ACC-01 to COR-01) are authoritative for this exercise, whatever wording the group adopted: ACC-01, multi-factor authentication for all remote access and all administration privileges; ACC-02, quarterly review of access privileges on business databases; INC-01, notification of any major incident to the Group CISO within 2 hours; JRN-01, log collection toward the group's centralized SOC; COR-01, every critical patch applied within 14 days.

No.	Reported finding
C1	Santé: business applications running on local passwords, without multi-factor authentication, and permanent remote maintenance access of the HIS vendor through a single identifier shared between nine people, in deviation from ACC-01 and from control A.8.5 "Secure authentication" of the framework
C2	Santé: analysis machines and imaging consoles on the same IP range as office IT, with an identical local administration account across the fleet, with regard to A.8.22 "Segregation of networks" and A.8.2 "Privileged access rights"
C3	Logistique: office and industrial networks interconnected, without segmentation, in deviation from A.8.22
C4	Logistique: domain account shared with the WMS third-party maintenance provider, used by a number of people nobody can establish, with regard to A.5.19 "Information security in supplier relationships" and A.8.2
C5	Éducation: administration accounts shared between the teams of the cluster's two subsidiaries, a consequence of the shared IT department, with nobody able to say who did what, with regard to A.5.16 "Identity management" and A.8.2
C6	Territoires: logs kept locally for six months, not forwarded to the group's centralized SOC, never consulted except on request, in deviation from JRN-01 and from A.8.15 "Logging"; the head of the SOC has put the Éducation & Territoires cluster on his connection plan, with no date, and his request for a contact with the cluster's IT Director has gone unanswered
C7	Logistique-Santé inter-subsidiary flow: dedicated VLAN and inspection firewall in place on the emergency replenishment API, the only network segregation found in the group; the flow has been suspended for three months at the request of the Santé subsidiary CISO; with regard to A.8.22
C8	Éducation: eleven subscriptions to online services taken out by teaching teams outside the IT department, with no contract and no impact assessment, the shadow IT seen in session 2, with no precise requirement of the audit scope directly violated, but with an attack surface impossible to inventory

Expected output: the grading table.

1. **Grade** each of the eight findings: compliant, major nonconformity, minor nonconformity, or observation.
2. **Justify** each grading in one sentence that cites the requirement and the extent of the deviation, never an impression of severity.
3. **Flag** the two findings whose grading can legitimately be debated, and write in one line the argument of each side.



Answer keys and assessment criteria – cliquer pour révéler